RBAC (Role-Based Access Control)

The system uses 4 clear roles: admin, doctor, secretary, and patient.

Role identity is loaded at login and stored in session ($_SESSION['role']) for authorization.
Each role has its own protected portal: admin.php, doctor.php, secretary.php, patient.php.
Server-side guard check_session([...]) enforces allowed roles before page/module access.
Role mapping is backed by the database role table and users.role_id.

Security Features

1. Authentication and Password Security

Passwords are hashed using bcrypt (PASSWORD_BCRYPT) before storage.
Login uses secure password verification and supports secure hash upgrades.
Password policy is enforced (minimum length + uppercase + lowercase + number + special character).

2. Session Security

HttpOnly: The cookie can't be accessed by JavaScript, reducing the risk of theft via cross-site scripting (XSS).
SameSite=Lax: Limits when cookies are sent with requests from other sites, helping prevent cross-site request forgery (CSRF).
Secure flag: Ensures cookies are only sent over HTTPS, not insecure HTTP.

3. Session Timeout and Idle Control

The system tracks last_activity in session and expires inactive sessions automatically.
Role-based idle behavior is implemented (patient and staff timeout policies).
Session keep-alive endpoint updates activity safely during active usage.

4. CSRF Protection

CSRF tokens are generated per session and validated on protected actions.
Token comparison uses hash_equals for safe, timing-attack-resistant checks.
CSRF is applied to core auth and management flows (login, register, password change, add/update user/patient).

5. Brute-Force Login Protection

Failed login attempts are counted for both users and patients.
Accounts are temporarily locked after repeated failed attempts.
Counters and lock status are reset after successful authentication.

6. Input Validation and Secure DB Access

Inputs are sanitized
Email and key fields are validated server-side before processing.

Database operations use prepared statements with bound parameters.

7. System Logging

user_logs and patient_logs store login time, last activity, logout time, and IP address.
system_logs records action type, entity context, details, IP, and user-agent.
Auth lifecycle events (login/logout) are logged for traceability.